NEXONAI CONSULTING

BRIEF PENTRU AUDITOR

unpruuf audit de securitate

Despre ce este vorba şi ce are de făcut auditorul dacă acceptă mandatul.

NexonAI Consulting SRL · 27.10.2026 · unpruuf@nexonai.ro

unpruuf nu este auditat şi nu este certificat. Acest document descrie sistemul şi cere o verificare independentă; nu conţine nicio promisiune de protecţie.

Cuprins

1. Rezumat

2. Ce este unpruuf

3. Perimetrul propus

4. Ce afirmăm

5. Limite cunoscute

6. Ce are de făcut auditorul

7. Conţinutul raportului

8. Ce punem la dispoziţie

9. Reguli ale colaborării

10. De stabilit împreună

1. Rezumat

NexonAI Consulting SRL dezvoltă **unpruuf**: comunicare fără identităţi, cu servere operate chiar de client. Produsele sunt unpruuf Business şi unpruuf Compliance (canal de raportare), ambele testate de noi, şi unpruuf Press, aflat în pilot.

Căutăm un **auditor independent de securitate** care să verifice dacă afirmaţiile noastre de securitate rezistă. Acest document explică ce este unpruuf, ce se află în perimetru, ce afirmăm, ce limite cunoaştem deja şi ce ar avea de făcut auditorul dacă acceptă mandatul.

> **Stare actuală:** unpruuf nu este auditat şi nu este certificat. Toate afirmaţiile din documentaţia noastră sunt o autoevaluare a dezvoltatorului, nu o confirmare externă. Tocmai de aceea căutăm un audit.

2. Ce este unpruuf

Sistemul are două părţi: o **aplicaţie** şi un **server operat de client**. NexonAI nu operează servere şi nu are acces la mesaje.

- **Fără identităţi:** fără conturi, fără numere de telefon, fără director. Un contact se adaugă printr-un cod schimbat între cele două persoane (cod QR).
- **Cutie poştală, nu mesagerie directă:** expeditorul depune un pachet sigilat în propria cutie poştală de pe serverul clientului, iar contactul îl ridică. Răspunsul merge pe acelaşi drum.
- **Loc de trecere, nu depozit:** ce rămâne pe server dispare după cel mult o zi (TTL configurabil de operator).
- **Trafic prin Tor:** aplicaţia comunică cu serverul prin Tor (SOCKS).
- **Pachete de dimensiune fixă:** fiecare pachet are exact 4096 de octeţi, pentru ca lungimea mesajului să nu se vadă.
- **Criptare:** Double Ratchet (X25519, HKDF, XChaCha20-Poly1305) cu un strat exterior de transport AES-256-GCM; identificator de cale per contact derivat cu HMAC-SHA256 şi rotit orar; baza de date locală cu contacte criptată cu SQLCipher; PIN cu PBKDF2.
- **Licenţă:** o licenţă acoperă un server.

Canalul de raportare (unpruuf Compliance)

Aplicaţia responsabilului de caz (Node.js/TypeScript) primeşte rapoartele prin acelaşi mecanism şi le păstrează într-o bază SQLite criptată. Un panou afişează numere de caz şi termenele din Directiva (UE) 2019/1937 (7 zile pentru confirmare, 3 luni pentru răspuns). Raportorul poate folosi aplicaţia Android sau o pagină web în browser; varianta web nu foloseşte Tor şi oferă o protecţie mai slabă, ceea ce este indicat pe primul ecran.

3. Perimetrul propus

COMPONENTĂ	TEHNOLOGIE	ÎN PERIMETRU
Aplicaţia Android	Kotlin, ediţii standard, pro, client, group, whistleblower, press	Da, prioritar
Serverul (relay)	Node.js/TypeScript, rulează în Docker sau ca proces Windows/Mac cu Tor propriu	Da, prioritar
Relay pe Android	Kotlin, acelaşi protocol HTTP ca serverul	Da
Aplicaţia responsabilului de caz şi panoul	Node.js/TypeScript, SQLite criptat	Da
Interfaţa web a raportorului	Browser, fără Tor	Da, cu aşteptări reduse
Cod iOS, node-mesh-server	În lucru / în afara versiunilor livrate	Nu
Tor, sistemul de operare, dispozitivul, infrastructura clientului	Terţi	Nu, dar ipotezele despre ele trebuie evaluate

4. Ce afirmăm (de verificat de către auditor)

Lista completă, cu ipotezele fiecărei afirmaţii, se află în fişierul *SECURITY_CLAIMS.md*. Pe scurt:

- Fiecare pachet de pe fir are exact 4096 de octeţi, deci lungimea unui mesaj scurt nu se poate deduce din dimensiune. Fişierele şi pozele merg în mai multe pachete, deci pentru ele dimensiunea este doar aproximativă.
- Identificatorul de cale al unui contact este indistinguibil de o valoare aleatoare pentru un observator care nu cunoaşte secretul perechii şi nu poate fi legat între contacte.
- Compromiterea ulterioară a unui dispozitiv nu deschide mesajele deja trimise sau primite (secretul înainte, prin Double Ratchet).
- Mesajele nu se scriu pe disc; la ieşirea din aplicaţie sau la blocarea ecranului sunt şterse din memorie.
- Serverul vede doar blocuri criptate, adresate printr-o etichetă rotitoare, şi le şterge după TTL. Nu stochează identităţi.
- Nu există un server al NexonAI care să poată fi atacat sau obligat să predea date.

Auditorul ne spune pentru fiecare afirmaţie dacă este **confirmată**, **confirmată cu rezerve** sau **neconfirmată**, şi de ce.

5. Limite pe care le cunoaştem deja

Le declarăm dinainte, ca auditorul să nu piardă timp redescoperindu-le şi să se concentreze pe ce nu ştim.

- Nu a avut loc niciun audit independent.
- Izolarea adreselor este parţială: noile asocieri folosesc aceeaşi adresă onion principală a dispozitivului; doi contacte care se consultă pot observa că vorbesc cu aceeaşi adresă.
- O adresă onion separată, rotită zilnic, pentru contactele verificate nu a fost încă testată pe Tor real.
- Descoperirea în reţeaua locală (mDNS) emite încă o valoare unică pentru dispozitiv, vizibilă oricui din aceeaşi reţea Wi-Fi.
- Un PIN scurt oferă puţină entropie; PBKDF2 încetineşte încercările, dar nu creează entropie.
- PIN-ul de panică este o funcţie de constrângere, nu una criptografică.
- Regulile ediţiei (de exemplu „clientul se asociază doar cu pro”) sunt politică în aplicaţie, nu o barieră criptografică.
- Corelarea globală a traficului la nivel de Tor nu este rezolvată de noi şi nici de altcineva.
- Nu există grupuri şi notificări push, fiindcă nu există identităţi; mesajele neridicate într-o zi dispar.

6. Ce are de făcut auditorul dacă acceptă

PAS	CE SE FACE	REZULTAT
1. Pregătire	Semnarea acordului de confidenţialitate şi a mandatului. Auditorul confirmă în scris că este independent şi că nu are legături comerciale cu NexonAI în afara auditului.	Mandat semnat
2. Preluare materiale	Primirea codului sursă, a documentaţiei, a instrucţiunilor de build şi a unei instanţe de test (server plus aplicaţii).	Mediu de lucru funcţional
3. Model de ameninţare	Confirmarea sau corectarea modelului nostru de adversari: observator pasiv, operator de server compromis, contact rău intenţionat, dispozitiv pierdut, autoritate cu ordin judecătoresc.	Model de ameninţare convenit
4. Criptografie şi protocol	Verificarea Double Ratchet, a stratului exterior, derivării identificatorilor, rotaţiei, gestionării cheilor, a generării numerelor aleatoare şi a protecţiei PIN şi bazei locale.	Constatări criptografice
5. Revizuirea codului	Aplicaţia Android, serverul, aplicaţia responsabilului de caz şi panoul: autentificare, validarea intrărilor, gestionarea erorilor, jurnale şi date care rămân pe disc sau în memorie.	Constatări de cod
6. Teste active	Teste de penetrare pe server şi pe panou: autentificare, injecţii, limite de rată, ştergere TTL, izolare între cutii poştale, scurgeri în jurnale.	Constatări din teste

7. Reţea şi metadate	Analiza traficului prin Tor: dimensiuni, ritm, ce poate observa un operator de server şi ce poate observa un observator de reţea.	Evaluare a metadatelor
8. Lanţ de build	Verificarea dependenţelor, a semnării şi a faptului că build-ul livrat corespunde codului sursă.	Constatări privind lanţul de build
9. Raport	Raport scris cu toate constatările şi opinia asupra fiecărei afirmaţii din secţiunea 4.	Raport final
10. Reverificare	După remedierea noastră, auditorul reverifică punctele critice şi actualizează raportul.	Raport actualizat

7. Ce trebuie să conţină raportul

- Rezumat pentru conducere, pe o pagină, fără jargon.
- Pentru fiecare constatare: titlu, gravitate, descriere, cum poate fi reprodusă, impact şi recomandare.
- Opinia asupra fiecărei afirmaţii din secţiunea 4, în trei trepte (confirmată, cu rezerve, neconfirmată).
- Ce nu a fost verificat şi de ce (perimetru, timp, acces).
- Un rezumat public, formulat de auditor, pe care îl putem arăta clienţilor, cu acordul auditorului asupra formulării.

8. Ce punem la dispoziţie

- Cod sursă complet al componentelor din perimetru.
- Documentaţie: SECURITY_CLAIMS.md (afirmaţii şi limite), STATUS.md (funcţii şi istoric), COMPLIANCE.md, instrucţiuni de instalare şi pornire.
- O instanţă de test cu server şi aplicaţii, plus fişiere de instalare şi pornire.
- Răspunsuri la întrebări în termen convenit.
- Remedierea constatărilor şi predarea unei versiuni noi pentru reverificare.

9. Reguli ale colaborării

- **Independenţă:** auditorul nu primeşte instrucţiuni asupra concluziilor. Raportul rămâne al lui, nu îl editează NexonAI.
- **Formulare:** NexonAI foloseşte cuvântul „auditat” doar pentru perimetrul şi versiunea acoperite de raport, şi nu foloseşte „certificat” decât dacă raportul o spune.

- **Confidenţialitate:** constatările rămân confidenţiale până la remediere; termenul de remediere se stabileşte împreună.
- **Fără garanţii:** nici raportul, nici acest document nu promit că oamenii sau sursele sunt protejate. Ele descriu cum este construit sistemul şi ce s-a verificat.

10. De stabilit împreună

SUBIECT	STARE
Durată şi calendar	De convenit
Onorariu şi mod de facturare	De convenit
Forma raportului şi limba (RO sau EN)	De convenit
Nivelul de detaliu al testelor active	De convenit
Termenul de remediere şi de publicare	De convenit

Pentru întrebări sau pentru a cere o ofertă: **unpruuf@nexonai.ro**